

Active Directory Hardening & Risk Reduction

PingCastle Assessment Portfolio — adforest.local

Assessment Date: 02 May 2026 | Windows Server 2025 | Domain: adforest.local

1. Executive Summary

This document presents a structured Active Directory security hardening exercise performed on a Windows Server 2025 homelab domain (adforest.local). PingCastle Free Edition was used as the primary assessment tool across three scan cycles. Through targeted remediation — including password policy enforcement, NTLMv1 disablement, Windows LAPS deployment, privileged account restructuring, and AD backup compliance — the domain risk score was reduced from 60 to 20, a 67% improvement with no third-party tooling beyond LAPS.

Metric	Value
Domain	adforest.local
Domain Controller	WIN-ESVD1CAD1FJ
Operating System	Windows Server 2025
Domain Functional Level	Windows Server 2016 (Level 10)
Schema Version	91
Assessment Tool	PingCastle Free Edition
Final Assessment Date	02 May 2026

2. Score Progression

PingCastle scores each domain across four risk categories on a 0–100 scale. The Global Score equals the highest individual category score. Lower is better. The table below shows the progression across three assessment cycles.

Assessment	Global Score	Stale Objects	Privileged Accounts	Trusts	Anomalies
Baseline (Report 2)	60	—	—	—	—
Post-Hardening (Report 12)	35	20	20	0	35
Final (Report 13)	20	20	0	0	20

The Privileged Accounts category reaching 0 is particularly significant, reflecting the effectiveness of the account restructuring and LAPS deployment. The Anomalies score reduction from 35 to 20 was directly attributable to resolving the AD backup compliance finding (A-BackupMetadata, +15 points).

3. Hardening Actions

3.1 Password Policy Enforcement

The default domain password policy was reviewed and strengthened via Group Policy. Minimum password length and complexity requirements were enforced, addressing baseline findings related to weak authentication controls.

3.2 NTLMv1 Disabled

The LAN Manager authentication level was configured to transmit NTLMv2 responses only and to refuse LM and NTLMv1 authentication. This was applied via GPO under Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options. NTLMv1 is a legacy protocol with known cryptographic weaknesses and should not be permitted in any modern AD environment.

3.3 AES Encryption Enforced

Kerberos encryption was restricted to AES128 and AES256. RC4 and DES encryption types were removed from supported configurations on privileged accounts, aligning with current Microsoft security guidance and reducing exposure to Kerberoasting and similar attacks.

3.4 Windows LAPS Deployed

Windows LAPS (Local Administrator Password Solution) was deployed via GPO across domain-joined machines. LAPS generates unique, automatically rotating passwords for local administrator accounts and stores them securely as confidential AD attributes, accessible only to authorised accounts. This eliminates the risk of lateral movement through shared local administrator passwords.

3.5 AD Recycle Bin Enabled

The Active Directory Recycle Bin was enabled via Active Directory Administrative Center. This feature allows recovery of accidentally deleted AD objects without requiring an authoritative restore from backup, reducing operational risk and recovery time.

3.6 MachineAccountQuota Set to 0

The ms-DS-MachineAccountQuota attribute on the domain root was set to 0, preventing non-privileged users from joining machines to the domain. The default value of 10 is a known attack vector exploited in techniques such as resource-based constrained delegation abuse.

3.7 Privileged Account Structure

A dedicated SecAdmin account was created for administrative tasks, following the principle of least privilege and separating day-to-day user activity from privileged operations. The built-in Administrator account was renamed to BreakGlass and disabled, reducing the attack surface for credential-based attacks targeting the well-known default account name.

3.8 AD Backup Compliance (A-BackupMetadata)

PingCastle flagged the absence of a Microsoft-standard AD backup as a +15 point finding. The wbadmin utility requires a dedicated volume separate from the source being backed up. To resolve this on a single-disk system, a 40GB dynamically expanding VHD was created at C:\BackupVHD\adbackup.vhd using the Hyper-V PowerShell module and mounted as drive D:. A full system state backup was then executed successfully on 02/05/2026 at 13:11, updating the DIT Database Partition Backup Signature and clearing the finding on the next scan.

4. AD Backup Architecture

The backup solution was designed to satisfy wbadmin's volume separation requirement without additional physical hardware. A Dynamic VHD provides an independent drive letter while the backing file resides on the existing C: volume.

Component	Detail
VHD File Location	C:\BackupVHD\adbackup.vhd
VHD Type	Dynamic (expands on demand)
VHD Size	40 GB maximum
Mounted As	Drive D: (ADBackup)
Backup Method	wbadmin start systemstatebackup -backuptarget:D:
Backup Completed	02/05/2026 13:11
Log Location	C:\WINDOWS\Logs\WindowsServerBackup\
Writers Completed	System Writer, COM+ REGDB, DFS Replication, Registry Writer, WMI Writer, NTDS

The previous C:\ADBackup folder (non-standard backup, ~30GB) was removed after the wbadmin backup completed successfully, reclaiming disk space.

5. Remaining Findings (Score 20)

The following findings remain in the final scan. Each represents a known, accepted risk in the current homelab context with documented rationale.

Finding	Category	Points	Notes
Stale user/computer objects	Stale Objects	20	Lab accounts created during testing phases
Authenticated Users can create DNS records	Anomalies	Medium	DNS ACL hardening required
PowerShell audit not fully enabled	Anomalies	Medium	ScriptBlock/Module logging pending
DSHeuristics CVE-2021-42291	Anomalies	Medium	Planned next hardening cycle

mitigation			
Residual privileged group rule	Privileged Accounts	Low	1 rule matched — near-clean

6. Tools & Technologies

Tool	Purpose
PingCastle Free Edition	AD health and risk scoring across four categories
Group Policy Management Console	GPO creation, linking, and enforcement
Active Directory Users & Computers	Account management and OU structure
Windows LAPS	Local administrator password rotation and storage
wbadmin	Microsoft-standard system state backup
Hyper-V PowerShell Module	VHD creation (New-VHD, Mount-VHD)
PowerShell	Disk initialisation, partition creation, formatting
BloodHound CE	AD attack path enumeration (separate portfolio entry)
Splunk Enterprise	SIEM integration and dashboard creation (separate entry)

7. Key Takeaways

- PingCastle provides an objective, repeatable metric for AD security posture — ideal for demonstrating measurable improvement in a portfolio context.
- A 67% score reduction (60 → 20) was achieved through configuration hardening alone, with no third-party security tooling beyond Windows LAPS.
- The backup compliance finding (A-BackupMetadata) illustrates how infrastructure gaps — not just misconfiguration — contribute to risk scoring.
- VHD-based backup targets are a practical and industry-aligned solution for wbadmin volume restrictions in single-disk environments.
- Privileged account hygiene (renamed BreakGlass, dedicated SecAdmin, MachineAccountQuota=0, LAPS) reduced the Privileged Accounts score to 0.
- Remaining findings (DNS ACLs, PowerShell auditing, DSHeuristics) represent the next hardening cycle and are documented as planned remediation.